

Assinatura Stripe— Documentação de Regras de Negócio

Plataforma de assinaturas com pagamento recorrente via Stripe, liberação de acesso controlada por confirmação assíncrona de pagamento.

1. Visão geral

O sistema permite que um usuário assine um plano mensal recorrente. O pagamento é processado pelo Stripe (página hospedada por eles, não pelo próprio sistema), e a confirmação de que o pagamento foi bem-sucedido chega de forma assíncrona, via webhook — nunca através do simples retorno do navegador.

2. Entidades principais

Entidade	Descrição
User	Usuário do sistema, vinculado a um Customer do Stripe
Plan	Plano de assinatura disponível, espelhando um Price cadastrado no Stripe
Subscription	Vínculo entre um User e um Plan, com status e data de renovação
WebhookEvent	Registro de cada evento do Stripe já processado, usado para evitar duplicação

3. Regras de negócio

3.1 Confirmação de pagamento

- O redirecionamento de sucesso do Stripe, por si só, nunca libera acesso — ele apenas confirma que o formulário de pagamento foi preenchido.
- A liberação real de acesso só acontece quando o webhook `checkout.session.completed` é recebido e validado.
- Toda assinatura nasce vinculada a um Customer do Stripe, criado automaticamente no primeiro checkout do usuário.

3.2 Idempotência

- O Stripe pode reenviar o mesmo evento mais de uma vez (falha de rede, timeout, etc).
- Cada evento processado é registrado por seu ID único (WebhookEvent); um evento repetido é identificado e ignorado, nunca duplicando uma assinatura.

3.3 Segurança do webhook

- Toda requisição recebida no endpoint de webhook tem sua assinatura criptográfica validada

contra um segredo compartilhado com o Stripe.

- Requisições com assinatura inválida são rejeitadas antes de qualquer processamento.

3.4 Status de assinatura

Status	Significado
incomplete	Assinatura criada, pagamento ainda não confirmado
active	Pagamento confirmado, acesso liberado

past_due	Cobrança recorrente falhou, aguardando nova tentativa
canceled	Assinatura cancelada, acesso bloqueado

- Somente o status active libera acesso à área restrita do sistema.

4. Fluxos principais

4.1 Assinatura de um plano

1. Usuário autenticado escolhe um plano na tela de checkout.
2. Sistema cria (ou reaproveita) um Customer no Stripe para esse usuário.
3. Sistema cria uma Checkout Session e redireciona o usuário para a página de pagamento do Stripe.
4. Usuário preenche os dados de pagamento na página do Stripe.
5. Usuário é redirecionado de volta ao sistema — mas o acesso ainda não é liberado nesse momento.

4.2 Processamento do webhook

1. Stripe envia o evento checkout.session.completed para o endpoint de webhook.
2. Sistema valida a assinatura do evento.
3. Sistema verifica se esse evento já foi processado antes; se sim, ignora.
4. Sistema localiza o usuário pelo Customer do Stripe e cria/atualiza a Subscription com status active.
5. A partir desse momento, o middleware de acesso libera a área restrita para esse usuário.

5. Arquitetura (visão simplificada)

Diferente de usar um pacote pronto (como o Laravel Cashier), a integração foi construída diretamente sobre o SDK oficial do Stripe, para que cada decisão (idempotência, validação de assinatura, liberação de acesso) fosse explícita e compreendida.

- Checkout: Controller cria a sessão de pagamento e redireciona o usuário para o Stripe.
- Webhook: Endpoint dedicado, sem proteção CSRF (é uma chamada servidor-a-servidor), validando a assinatura antes de qualquer processamento.
- Gate de acesso: Middleware que verifica se o usuário tem uma Subscription com status active

antes de liberar rotas protegidas.